SECURITY GOVERNANCE & POLICY DEVELOPMENT

Purpose

This document defines GMDC security roles, governance responsibilities, and practical security policies aligned with the risks identified in the Week 4 risk register.

Security Roles & Responsibilities

Role	Responsibilities
Security Owner / Information Security Lead	Owns the security program, coordinates risk reviews, approves security requirements and reports significant issues to management.
System Administrator	Maintains servers and operating systems, manages accounts, applies approved patches and secure configurations.
Network Administrator	Maintains network controls, firewall rules and segmentation; restricts unnecessary network access and exposed services.
Asset / Data Custodian	Protects assigned information assets and ensures access and handling requirements are followed.
Authorized User	Uses systems only for approved duties, protects credentials and reports suspicious activity or incidents.
Incident Response / IT Security Team	Assesses reports, coordinates containment and recovery, preserves relevant evidence and documents incidents.
Management / Executive Authority	Approves policies, major security decisions and resources; reviews significant risks and security reports.

Governance Structure

Management / Executive Authority → Security Owner → System Administrator + Network Administrator + Incident Response / IT Security Team → Asset/Data Custodians → Authorized Users.

Management provides direction and approval. The Security Owner coordinates governance. Administrators implement controls.

Custodians protect assigned assets. Users follow approved rules and report incidents.

Information Security Policy

Purpose: Establish minimum requirements for protecting GMDC information, systems, services and technology assets.

Scope: All employees, interns, contractors, authorized users and GMDC information systems.

Requirements:

- Access systems only for authorized duties.
- Apply least privilege and remove access when no longer required.
- Prioritize critical and high-risk vulnerabilities from the approved risk register.
- Disable, remove or isolate unnecessary and unsupported services where practical.
- Report suspected security incidents promptly.
- Document and approve important security decisions.
- Verify controls through periodic review and vulnerability assessment.

Roles: Management approves; the Security Owner coordinates; administrators implement; users comply and report.

Enforcement: Violations may result in access suspension, investigation and management escalation.

Risk Alignment: Addresses compromised services, default credentials, legacy services, outdated systems, exposed services and weak access controls.

Password & Authentication Policy

Purpose: Reduce unauthorized access caused by weak, reused or default credentials.

Scope: All GMDC user, administrator, service and application accounts.

Requirements:

- Change default passwords before operational use.
- Use unique credentials and never share passwords.
- Separate administrative accounts from ordinary accounts where practical.
- Disable accounts when authorization ends.
- Change credentials suspected of compromise and review the affected account.
- Use stronger authentication such as MFA for privileged or sensitive access where supported.
- Do not transmit credentials through insecure legacy services.

Roles: Users protect credentials; administrators manage accounts; the Security Owner reviews authentication controls.

Enforcement: Repeated or deliberate violations may lead to access suspension and escalation.

Risk Alignment: Directly addresses default database credentials, insecure remote-access services and unauthorized-access risks.

Access Control Policy

Purpose: Ensure access is granted only to authorized people for legitimate duties.

Scope: All GMDC networks, servers, databases, applications, administrative interfaces and information assets.

Requirements:

- Grant access according to job duties and least privilege.
- Require approval for privileged or sensitive access.
- Limit administrative access to authorized administrators.
- Disable or restrict unnecessary network services and management interfaces.
- Restrict databases and sensitive services to required hosts/users.
- Review user and privileged accounts periodically.
- Avoid shared accounts unless technically necessary and controlled.
- Revoke access promptly when authorization ends.

Roles: Custodians identify required access; administrators implement permissions; the Security Owner reviews high-risk access; users use only authorized resources.

Enforcement: Unauthorized access or repeated violations may result in suspension, investigation and escalation.

Risk Alignment: Addresses exposed services, database access, legacy r-services, SMB exposure, Java RMI and other unnecessary access.

Incident Reporting & Response Policy

Purpose: Ensure security incidents are reported, assessed, contained and documented consistently.

Scope: All employees, interns, contractors and authorized users who observe or suspect a security incident.

Requirements:

- Report suspected unauthorized access, malware, exposed credentials, unusual activity or lost devices promptly.
- Provide known facts, affected system/account, approximate time and relevant evidence.
- Do not intentionally alter or destroy potential evidence.
- The Incident Response / IT Security Team assesses and coordinates response.
- Escalate critical incidents to the Security Owner and management.
- Document containment and recovery actions.
- Preserve relevant evidence and conduct lessons-learned reviews after significant incidents.

Roles: Users report; the Incident Response/IT Security Team coordinates; the Security Owner escalates; management receives significant-incident reports.

Enforcement: Failure to report significant incidents or deliberate interference may result in corrective action and escalation.

Risk Alignment: Addresses backdoors, vulnerable services, unauthorized access and the potential impact of successful exploitation.

Policy-to-Risk Alignment

Risk Category	Policy	Governance Response
Compromised/backdoored services	Information Security + Incident Reporting	Secure service management, prompt reporting, containment and verification.
Default/weak credentials	Password & Authentication + Access Control	Replace defaults, protect credentials and apply least privilege.
Exposed network services	Access Control + Information Security	Restrict unnecessary services and administrative interfaces.
Legacy/unsupported systems	Information Security	Prioritize remediation, replacement, isolation or removal.
Web/server weaknesses	Information Security + Access Control	Secure configuration, reduced exposure and verification.
Unauthorized access/incidents	Access Control + Incident Reporting	Define authorization, escalation and response responsibilities.

Review & Approval

These documents should be reviewed periodically and whenever significant changes occur to GMDC systems, responsibilities or the risk register. Exceptions should be documented and approved by the appropriate authority.

Document Status: Proposed for management review and approval.